

# Proibida a reprodução e comercialização sem autorização

Usuário: Julio Cesar Justini dornellas, julio.justini@gmail.com, CPF: 05536778960

## Procedimentos de Segurança da Informação (Senhas, Autenticação, Etc.)

### 1. Introdução

Os procedimentos de **segurança da informação** envolvem uma série de medidas que visam proteger os dados e os sistemas das organizações. Um ponto fundamental nesse contexto é a **política de segurança da informação**, que consiste em um **conjunto de diretrizes, normas e procedimentos** estabelecidos pela **organização** com o objetivo de **conscientizar e orientar todos os envolvidos**.

Essa conscientização deve abranger não apenas os servidores, mas também diretores, funcionários com funções subalternas, terceirizados, fornecedores, estagiários, parceiros e até clientes. Todos devem compreender a importância de seguir as normas estabelecidas, pois **o fator humano é considerado o elo mais fraco da cadeia de segurança da informação**.

Um simples descuido, como anotar senhas em um pedaço de papel, pode comprometer toda a segurança, uma vez que qualquer pessoa com acesso a esse papel pode utilizar indevidamente aquelas credenciais, assumindo falsamente a identidade do usuário.

Por isso, investir em treinamento, educação e conscientização é essencial. Quando as pessoas compreendem os motivos por trás de determinadas medidas e controles implementados pela organização, torna-se mais fácil garantir altos níveis de segurança.

A informação precisa ser transmitida de maneira clara, explicando os riscos e as consequências de práticas inadequadas, além de orientar sobre os comportamentos mais seguros no ambiente digital.

No contexto da segurança da informação, é importante entender o que são senhas e logins. **A senha é um conjunto de caracteres que, juntamente com o login — ou nome de usuário —, permite que um sistema identifique e reconheça quem está tentando acessá-lo.**

### 2. Tríade da segurança da informação: Confidencialidade, Integridade e Disponibilidade (CID)

Para compreender de forma clara os fundamentos da segurança da informação, é imprescindível o domínio da chamada **tríade CID — Confidencialidade, Integridade e Disponibilidade**. Esses três princípios formam a base conceitual sobre a qual são construídas as **políticas e os procedimentos de proteção da informação**.

A **Confidencialidade** refere-se à **garantia de que apenas pessoas autorizadas terão acesso a determinada informação**. Isso significa que dados sensíveis devem ser protegidos contra o acesso indevido por terceiros, sejam eles mal-intencionados ou não.

Um exemplo clássico é a proteção de senhas em sistemas de internet banking: apenas o titular da conta deve conseguir acessar essas informações, e mecanismos como autenticação de dois fatores e criptografia são empregados para assegurar a confidencialidade.

A **Integridade**, por sua vez, está relacionada à **exatidão e à consistência da informação ao longo do tempo**. Trata-se de garantir que os dados não sejam alterados de maneira indevida, acidental ou proposital, durante seu armazenamento, processamento ou transmissão.

Um exemplo típico de medida para assegurar a integridade é o uso de assinaturas digitais ou de somas de verificação (checksums) para verificar se um arquivo foi corrompido ou modificado após ser transmitido.

Já a **Disponibilidade** diz respeito à **garantia de que a informação estará acessível e utilizável sempre que necessário**. Isso envolve assegurar que os sistemas, serviços e dados estejam operacionais para os usuários autorizados, mesmo diante de falhas técnicas ou ataques cibernéticos.

Um exemplo claro é a implementação de sistemas de backup e redundância para manter sites e bancos de dados disponíveis mesmo em caso de pane em servidores principais.

#### Tríade da segurança da informação

|                   |             |                 |
|-------------------|-------------|-----------------|
| C                 | I           | D               |
| Confidencialidade | Integridade | Disponibilidade |

Dentro desse contexto, é igualmente fundamental distinguir entre os conceitos de **ameaças e vulnerabilidades**, pois eles fazem parte da base teórica e prática da segurança da informação. Uma **ameaça é qualquer evento ou agente com potencial de causar danos à informação ou aos sistemas que a processam**.

A ameaça pode ser **intencional**, como um ataque de um hacker, ou **acidental**, como uma falha elétrica que corrompe dados. Já a **vulnerabilidade é uma fragilidade ou brecha** em um sistema, procedimento ou configuração que pode ser explorada por uma ameaça para causar um incidente de segurança.

Por exemplo, um software desatualizado pode conter falhas conhecidas que representam uma vulnerabilidade — se um atacante identificar essa brecha e explorá-la com um vírus ou um ataque de negação de serviço, a ameaça se concretiza.

Portanto, uma organização eficaz em segurança da informação é aquela que compreende a importância da tríade CID, que identifica suas ameaças, que avalia suas vulnerabilidades e que estabelece controles e procedimentos para reduzir os riscos decorrentes desses elementos.

### 3. Classificação da Informação

A **classificação da informação** é um procedimento essencial dentro da gestão da segurança da informação, pois permite identificar o grau de proteção que cada tipo de dado exige com base em sua importância e nos riscos associados ao seu uso indevido.

Em outras palavras, **classificar a informação é reconhecer que nem todos os dados possuem o mesmo valor ou grau de sensibilidade** para uma organização ou instituição pública, sendo necessário **aplicar níveis diferenciados de segurança e controle**.

Esse processo facilita a adoção de medidas adequadas para proteger a informação ao longo de todo o seu ciclo de vida — desde sua criação até o descarte.

Os critérios mais utilizados para a classificação da informação são a sensibilidade e a criticidade. A **sensibilidade diz respeito ao potencial de dano caso a informação seja divulgada de forma não autorizada**.

Informações sensíveis normalmente envolvem dados pessoais, financeiros, estratégicos ou jurídicos que, se expostos, podem comprometer a privacidade de indivíduos ou a competitividade e a reputação de uma organização.

Já a **criticidade está relacionada ao impacto que a indisponibilidade ou a perda dessa informação causaria para os processos operacionais da organização**. Informações críticas são aquelas cujo uso é essencial para o funcionamento contínuo de sistemas e serviços, como dados de controle de produção em uma indústria ou registros de pacientes em um hospital.

Com base nesses critérios, estabelecem-se níveis comuns de classificação da informação, os quais podem variar de organização para organização, mas geralmente seguem um padrão básico dividido em quatro categorias: **pública, interna, confidencial e restrita**.

A **informação pública** é aquela cujo **acesso é irrestrito**, podendo ser **divulgada a qualquer pessoa sem causar prejuízos**. Exemplos incluem informes institucionais, manuais de uso de produtos disponíveis em sites oficiais e dados estatísticos amplamente divulgados por órgãos públicos. Mesmo sendo pública, essa informação deve ser protegida contra alterações indevidas para garantir sua integridade.

A **informação interna** é destinada ao **uso exclusivo de membros da organização**, embora não contenha dados altamente sensíveis. Ela não deve ser divulgada fora do ambiente corporativo ou institucional, mas seu vazamento pode não causar danos graves. Relatórios de desempenho interno, atas de reuniões e instruções operacionais são exemplos desse tipo de informação.

A **informação confidencial** exige um nível mais elevado de proteção, pois seu **acesso é restrito a grupos específicos e autorizados dentro da organização**. O vazamento desse tipo de informação pode acarretar prejuízos financeiros, legais ou à imagem da entidade. Exemplos incluem dados de clientes, contratos em negociação, estratégias de mercado e informações de folha de pagamento.

Já a **informação restrita** é a mais sensível e crítica entre todas as classificações. O acesso a esse tipo de informação é altamente limitado, sendo **autorizado apenas a pessoas específicas que realmente necessitam dela** para executar suas funções.

O vazamento, a alteração ou a indisponibilidade dessas informações pode gerar consequências catastróficas, como paralisação de serviços essenciais, comprometimento da segurança nacional ou graves infrações legais. Exemplos incluem senhas de sistemas, segredos industriais e informações de inteligência governamental.

Uma vez classificada a informação, é fundamental estabelecer procedimentos específicos para seu tratamento conforme sua classificação. Isso inclui a definição de quem pode acessar a informação, quais meios podem ser utilizados para seu armazenamento e transmissão, e como será realizado seu descarte seguro.

Por exemplo, uma informação classificada como confidencial deve ser armazenada em repositórios protegidos por autenticação forte e criptografia, e somente poderá ser enviada por canais de comunicação seguros. O descarte de documentos impressos confidenciais, por sua vez, deve ser feito por meio de fragmentação (trituradores), e não simplesmente descartados em lixo comum.

Além disso, políticas internas devem orientar os colaboradores sobre como manusear cada tipo de informação, estabelecendo penalidades em caso de descumprimento. Treinamentos e campanhas de conscientização são estratégias importantes para garantir que todos na organização compreendam e respeitem essas diretrizes.

Em resumo, classificar a informação com base na sua sensibilidade e criticidade é uma prática estratégica e obrigatória para garantir a segurança e a integridade dos dados, evitando prejuízos operacionais, financeiros, jurídicos e reputacionais.

## 4. Autenticação em Duas Etapas

Esse processo de verificação é conhecido como **autenticação**, que tem como objetivo garantir que a identidade apresentada é autêntica. Autenticar significa verificar se um objeto ou uma pessoa é realmente quem afirma ser.

Normalmente, isso é feito através do fornecimento do nome de usuário e da senha. No entanto, para aumentar ainda mais a segurança, é possível utilizar a **autenticação em duas etapas**, também chamada de **verificação em dois fatores**, autenticação dupla ou verificação em duas etapas.

Essa forma de autenticação adiciona uma **camada extra de proteção**, exigindo **duas formas diferentes de comprovação de identidade**. A primeira geralmente é a senha tradicional, e a segunda pode ser um código gerado por um dispositivo chamado token, por exemplo, que exibe senhas temporárias geradas automaticamente por um servidor.



Imagem de um Token

Hoje em dia, é muito comum o uso de tokens em aplicativos de celular, que desempenham a mesma função. Dessa forma, mesmo que um atacante descubra a senha de um usuário, ele não conseguirá acessar o sistema sem o segundo fator de autenticação, tornando o acesso não autorizado significativamente mais difícil.

A **conta de usuário**, que pode ser referida como nome de **login**, **nome de usuário** ou **username**, é uma **identificação única associada a cada pessoa que utiliza um sistema ou serviço**, especialmente na internet.

Sempre que se faz um cadastro em um serviço online, como um e-mail, é necessário escolher um login que será usado como identificação. Esse **login**, por sua vez, estará **sempre vinculado a uma senha**.

## 5. Contas e Senhas

Existem três grupos principais de mecanismos de autenticação, cada um com características distintas que contribuem para a verificação da identidade do usuário. O primeiro grupo é o da **autenticação biométrica**, que se baseia em **características físicas do próprio usuário**.

Esse tipo de autenticação utiliza dados únicos e intransferíveis, como **impressões digitais, o formato da palma da mão, a voz, a íris ou a retina**. Existem equipamentos capazes de escanear e analisar essas particularidades, e como cada indivíduo possui traços exclusivos, esse método é considerado bastante seguro.

O segundo grupo é o da **autenticação por posse**, ou **identificação proprietária**, que utiliza **elementos que somente o usuário possui**. Exemplos comuns incluem **cartões de senha bancária ou dispositivos de segurança como tokens**, que geram **chaves temporárias** para serem utilizadas na autenticação.

Esses itens funcionam como uma forma de garantir que apenas o titular possa acessar determinadas informações ou sistemas, já que são objetos físicos ou virtuais que não deveriam estar disponíveis a terceiros.

O terceiro grupo é o da **autenticação baseada em conhecimento**, conhecida como **identificação positiva**. Essa se fundamenta em **informações que apenas o próprio usuário conhece**, como **senhas ou respostas a perguntas de segurança**.

Em muitas situações, ao tentar acessar um sistema, o usuário se depara com questionamentos específicos sobre sua vida pessoal ou profissional, justamente para confirmar que se trata realmente da pessoa autorizada. Um exemplo prático dessa situação ocorreu durante o processo de licenciamento anual de um veículo, realizado por meio do celular.

Inicialmente, tentou-se realizar a autenticação via integração com os dados do INSS, que gerou uma série de perguntas extremamente específicas, como valores de imposto sobre o salário recebido em uma determinada empresa no ano de 1994.

Essas perguntas exigiam um nível de detalhamento que nem sempre está facilmente acessível à memória do usuário, o que demonstra o grau de personalização e exclusividade desse tipo de autenticação.

A complexidade dessas perguntas, embora possa parecer excessiva, tem justamente a finalidade de garantir que apenas o verdadeiro titular da informação possa responder corretamente. Apesar disso, quando essas questões se tornam inacessíveis até mesmo para o próprio usuário, é necessário recorrer a métodos alternativos de autenticação, mais práticos ou viáveis no momento.

Esse tipo de mecanismo ilustra bem a essência da identificação positiva: garantir a segurança por meio de algo que só o próprio usuário deveria saber. Assim, seja qual for o método utilizado, **a senha continua sendo um elemento central nos processos de autenticação, assegurando que o acesso seja concedido apenas a quem realmente tem permissão.**

### 5.1. Métodos Indevidos de Obtenção de Senha

No que diz respeito às senhas, é essencial compreender os diversos **métodos utilizados por atacantes para obtê-las de forma indevida.**

Essas práticas são amplamente descritas na cartilha de segurança do **CERT.br**, o Centro de Estudos, Respostas e Tratamento de Incidentes de Segurança no Brasil, uma fonte bastante confiável e frequentemente usada como base para questões de concursos públicos.

Segundo essa cartilha, há várias formas pelas quais uma senha pode ser descoberta, muitas vezes sem que o usuário sequer perceba.

Um dos métodos mais comuns é o **uso de senhas em computadores que estejam infectados por softwares maliciosos**, como os **spywares**. Esses programas são projetados para capturar tudo o que é digitado, armazenando informações como senhas e dados bancários.

Além dos spywares, existe ainda o risco de **espionagem por meio da própria webcam dos notebooks**, que hoje é um item praticamente padrão nesses dispositivos. Posicionada na parte superior da tela, a câmera pode ser usada para gravar os movimentos feitos no teclado, permitindo que um atacante consiga identificar as teclas pressionadas durante a digitação da senha.

Outro risco significativo ocorre quando o usuário **insere sua senha em sites falsos**, acreditando tratar-se de páginas legítimas. Esses sites são criados por atacantes justamente para capturar as credenciais digitadas, e uma vez que essas informações estejam em mãos erradas, podem ser utilizadas para realizar diversas ações maliciosas.

Há também a possibilidade de se descobrir senhas por meio de **tentativas de adivinhação**, e apesar de parecer algo ineficaz, a realidade é que existem programas que fazem esse tipo de tentativa com uma rapidez impressionante.

Esse tipo de ataque se torna ainda mais eficaz quando os usuários escolhem senhas fracas, baseadas em informações pessoais como datas de aniversário, números de telefone, documentos, CPF ou placas de veículos. Esses dados são facilmente exploráveis por algoritmos que combinam e testam essas informações de maneira automatizada.

Outro ponto crítico é a **utilização de senhas em ambientes onde os dados trafegam pela internet sem criptografia**. Quando isso acontece, qualquer pessoa com conhecimento técnico suficiente pode interceptar as informações transmitidas e capturar as credenciais utilizadas.

Da mesma forma, se a senha estiver armazenada em um arquivo não criptografado e esse arquivo for acessado por um invasor, a senha poderá ser facilmente descoberta com a simples leitura do conteúdo.

Há ainda as técnicas de **engenharia social**, que consistem em **manipular psicologicamente o usuário para que ele revele voluntariamente suas senhas**. Essa prática se aproveita da confiança, da distração ou da boa-fé das pessoas, muitas vezes utilizando e-mails falsos, sites fraudulentos ou até ligações telefônicas para enganá-las.

Por fim, existe o risco da **observação direta**, quando alguém acompanha visualmente os movimentos dos dedos no teclado ou observa os cliques em um teclado virtual. Isso pode ocorrer especialmente em locais públicos ou em ambientes onde há presença de desconhecidos.

Por esse motivo, é altamente recomendável que o usuário sempre tente ocultar seus movimentos ao digitar senhas, seja em teclados físicos ou virtuais, de modo a dificultar qualquer tentativa de captura por observação.

Essas práticas demonstram que a segurança de uma senha não depende apenas da sua complexidade, mas também da forma como ela é utilizada e protegida no dia a dia. **Conhecer essas técnicas de ataque é fundamental para adotar comportamentos mais seguros e evitar a exposição a riscos desnecessários.**

## 5.2. Métodos de Proteção de Senha

Ao lidar com senhas, é fundamental adotar uma série de cuidados que ajudam a preservar a segurança das informações pessoais e evitar acessos indevidos. Um dos primeiros cuidados é **garantir que não se está sendo observado ao digitar senhas**, seja por meio do teclado físico ou de teclados virtuais.

Esconder os movimentos das mãos ou do mouse é uma forma eficaz de prevenir que terceiros captem visualmente as credenciais inseridas. Também é essencial **nunca compartilhar senhas com outras pessoas**, mesmo em situações aparentemente inofensivas.

Compartilhar senhas com funcionários, por exemplo, para que realizem transações bancárias em nome do titular, é uma prática extremamente arriscada e deve ser evitada a todo custo.

Outro ponto importante é o **encerramento adequado de sessões em sites que exigem autenticação**. Ao acessar esses serviços, principalmente em computadores compartilhados ou públicos, deve-se sempre utilizar a opção de logout antes de deixar a máquina.

Isso evita que outro usuário, ao assumir o uso do equipamento, tenha acesso à conta e realize ações em nome do usuário anterior, o que pode trazer consequências sérias.

A **criação de boas senhas** é um dos pilares da segurança digital. Senhas devem ser criadas com critério, **evitando padrões previsíveis e informações pessoais fáceis de descobrir**. Além disso, **sempre que houver suspeita de que uma senha possa ter sido comprometida, é necessário alterá-la imediatamente**, sem esperar por uma confirmação.

Também é importante utilizar **senhas diferentes para serviços distintos**. Embora isso possa parecer trabalhoso, é uma medida que impede que o comprometimento de uma senha afete todas as demais contas de um mesmo usuário.

Na configuração de perguntas de segurança, deve-se evitar aquelas cujas respostas sejam óbvias ou facilmente acessíveis, como o time de futebol favorito ou o nome de um artista.

Informações desse tipo muitas vezes estão disponíveis em redes sociais ou em conversas públicas, facilitando a vida de quem tenta invadir contas alheias. O ideal é escolher perguntas cujas respostas sejam únicas e não divulgadas.

Outra recomendação essencial é o **uso de serviços criptografados**, especialmente quando há o fornecimento de senhas ou qualquer tipo de dado sensível.

A criptografia protege a transmissão de informações, impedindo que terceiros compreendam os dados mesmo que consigam interceptá-los. Por isso, sempre que possível, deve-se optar por **conexões seguras**, identificadas, por exemplo, pelo uso do protocolo HTTPS nos sites acessados.

Além de todos esses cuidados, é importante manter a privacidade nas redes e na vida digital como um todo. Evitar a divulgação de informações pessoais ajuda a reduzir as chances de que elas sejam utilizadas para adivinhar senhas ou montar ataques personalizados.

Muitos usuários escolhem senhas baseadas em gostos pessoais, como o nome de um cantor favorito, o que pode ser facilmente descoberto por alguém que tenha acesso às suas redes sociais. Manter esse tipo de informação reservado é uma forma eficaz de aumentar a segurança.

Por fim, a **proteção do próprio computador** também não pode ser negligenciada. É fundamental utilizar programas de segurança como **antivírus e firewall**, e garantir que esses softwares estejam sempre atualizados.

À medida que novas vulnerabilidades são descobertas, os desenvolvedores desses programas lançam atualizações que corrigem falhas e aumentam a proteção. Portanto, manter esses sistemas atualizados é um passo indispensável para garantir a segurança das senhas e de todas as demais informações que circulam pelo computador.



### 5.2.1. Elaboração de Senhas

Ao criar senhas, é comum ouvir a recomendação de que se deve sempre usar senhas fortes. No entanto, é importante entender o que realmente caracteriza uma senha forte e quais critérios devemos considerar para elaborá-la. **Uma boa senha precisa ser difícil de ser descoberta, mas ao mesmo tempo relativamente fácil de ser lembrada pelo próprio usuário.**

Criar uma senha extremamente complexa, com uma combinação de caracteres pouco usuais, pode resultar em esquecimento frequente, o que compromete sua utilidade. Por outro lado, criar uma senha simples demais pode torná-la vulnerável a ataques. O ideal, portanto, é encontrar um equilíbrio entre complexidade e memorização.

Existem práticas que devem ser evitadas ao máximo na criação de senhas. Em primeiro lugar, **nunca se deve utilizar informações pessoais**, como nome, sobrenome, número de documentos, placas de automóveis, números de telefone ou datas importantes. Esses dados são facilmente descobertos, principalmente por meio de redes sociais ou outras fontes públicas.

Outro ponto importante é **evitar sequências de teclado**, como 1QAZ2WSX ou QWERTASDFG, pois essas combinações seguem padrões visíveis no teclado e são comumente testadas por programas de quebra de senha.

Também **não se deve utilizar palavras que façam parte de listas públicas conhecidas**, como nomes de músicas, times de futebol ou personagens de filmes. Existem ferramentas que testam milhares dessas palavras em questão de segundos, tornando-as escolhas inseguras.

Por outro lado, para criar senhas realmente seguras, é recomendável **utilizar números aleatórios**, preferencialmente escolhidos ao acaso, o que torna a senha menos previsível. Além disso, **senhas mais longas são sempre mais seguras**. Ainda que inicialmente pareçam difíceis de memorizar, com o uso frequente o próprio usuário acaba assimilando naturalmente essas senhas.

Uma boa prática é usar **diferentes tipos de caracteres** na composição da senha. Isso significa **misturar letras maiúsculas e minúsculas, números, sinais de pontuação e caracteres especiais** como o arroba (@), o jogo da velha (#) e outros. **Quanto maior a diversidade de elementos, maior a complexidade e, consequentemente, maior a segurança da senha.**

## 6. Log

Além da criação de senhas, outro conceito fundamental no contexto da segurança da informação é o **log**. Log é o nome dado ao **arquivo que registra o histórico de ações de um usuário dentro de um sistema**. Sistemas bem projetados geram logs automaticamente durante o uso.

Esse arquivo contém informações detalhadas sobre tudo o que foi feito em um determinado período, como, por exemplo, o horário de acesso ao sistema, quais módulos foram utilizados e quais operações foram realizadas. Esses registros são extremamente úteis para a resolução de problemas.

Quando ocorre algum erro ou falha, o técnico responsável pode analisar o log para entender o que o usuário estava fazendo naquele momento, facilitando a identificação da causa do problema.

Os logs também são ferramentas valiosas em processos de auditoria. Eles permitem rastrear toda a atividade de um usuário, oferecendo um panorama completo das ações realizadas em determinada sessão.

Com isso, é possível **verificar eventuais comportamentos inadequados, identificar falhas de segurança e manter um controle mais rigoroso** sobre o uso dos sistemas, contribuindo para a integridade e a transparência das operações dentro da organização.

## 7. Recomendações da Cartilha CERT

## 7.1. Efetuar as Operações Bancárias

No contexto das **operações bancárias**, os procedimentos de segurança devem ser ainda mais rigorosos, e para isso é essencial seguir as recomendações da **cartilha do CERT**.

Ao realizar qualquer transação bancária pela internet, o primeiro cuidado deve ser **verificar a procedência do site acessado** e garantir que a conexão seja segura. Isso pode ser confirmado ao observar se o endereço eletrônico começa com o **protocolo HTTPS**, que indica a presença de criptografia e maior segurança na troca de dados entre o usuário e o servidor do banco.

Outro ponto fundamental é sempre **digitar o endereço do banco diretamente no navegador**, evitando clicar em links recebidos por mensagens ou disponíveis em páginas da internet.

Essa prática é importante porque é muito fácil vincular um texto aparentemente confiável a uma página maliciosa. Por exemplo, um link pode exibir [www.bancoexemplo.com.br](http://www.bancoexemplo.com.br), mas na verdade levar o usuário a um site fraudulento. Por isso, é essencial evitar o uso de links prontos, especialmente em mensagens suspeitas.

Também não é recomendável utilizar mecanismos de busca para encontrar o site do banco. Os endereços dos bancos costumam ser simples e diretos, e os resultados de buscas podem incluir páginas falsas criadas para enganar o usuário. Assim, digitar o endereço diretamente na barra de endereços do navegador é sempre mais seguro.

Durante o acesso aos serviços bancários, ao ser solicitado o uso do cartão de segurança, o usuário deve fornecer apenas a informação de uma posição específica, conforme solicitado pelo banco.

Se for requisitada mais de uma posição ao mesmo tempo, isso deve ser visto com desconfiança, pois pode indicar uma tentativa de ataque. Os criminosos têm interesse em obter todas as combinações daquele cartão, e um sistema legítimo nunca pedirá múltiplas chaves em um único acesso.

**Jamais se deve fornecer senhas ou dados pessoais por telefone.** Ligações que se passam por atendimentos bancários podem ser extremamente perigosas, pois os golpistas tentam obter informações confidenciais do usuário, se passando por representantes oficiais da instituição financeira. Nesse tipo de situação, a recomendação é não fornecer nenhuma informação sigilosa.

Mensagens recebidas por e-mail, SMS ou outros meios digitais, vindas de instituições com as quais o usuário não possui nenhum vínculo, também devem ser tratadas com desconfiança, especialmente se solicitarem dados pessoais ou a instalação de qualquer tipo de módulo de segurança.

Se não existe nenhuma relação com a instituição que está enviando a mensagem, não há justificativa para o contato. Portanto, essas mensagens devem ser ignoradas imediatamente.

Em caso de qualquer dúvida ou comportamento suspeito, a orientação é procurar diretamente o banco. O contato deve ser feito por meio da central de relacionamento ou com o gerente responsável pela conta.

Dessa forma, é possível confirmar a veracidade da solicitação recebida e, se necessário, tomar as medidas adequadas para garantir a segurança das informações e evitar fraudes. Seguindo essas recomendações, o usuário consegue minimizar significativamente os riscos envolvidos nas operações bancárias online.

Ao realizar operações bancárias, é essencial **evitar o uso de redes Wi-Fi públicas ou computadores de terceiros**. Redes públicas, por sua natureza aberta, podem estar sendo monitoradas por terceiros mal-intencionados que conseguem capturar os dados transmitidos, inclusive informações bancárias.

Da mesma forma, computadores de outras pessoas podem estar comprometidos com programas espíões, que registram tudo o que é digitado, capturando senhas e outras informações sensíveis. Por isso, essas práticas devem ser evitadas para garantir a segurança das transações.

Além disso, é altamente recomendável verificar com frequência o extrato bancário e o extrato do cartão de crédito. Essa verificação constante permite identificar qualquer movimentação suspeita logo no início, possibilitando a tomada de medidas imediatas, como bloqueio de cartão, cancelamento de acessos e comunicação com o banco ou operadora do cartão.



Embora as instituições financeiras geralmente assumam a responsabilidade por transações fraudulentas e ressarcam os valores, o processo de contestação costuma ser demorado e desgastante. Assim, prevenir esses problemas é sempre o melhor caminho, poupando tempo e evitando aborrecimentos.

Outro cuidado importante envolve a **instalação de módulos de segurança para internet banking**. Antes de instalar qualquer programa recomendado para acesso ao banco pela internet, é imprescindível confirmar sua origem. Muitos ataques ocorrem por meio da falsa exigência de instalação de programas que, na realidade, são maliciosos.

O ideal é entrar em contato com o banco, informar o nome do módulo e confirmar se aquele arquivo faz realmente parte do processo de segurança da instituição. Essa verificação simples pode evitar grandes prejuízos.

## 7.2. Uso de Navegadores da Internet

Quanto ao uso de navegadores na internet, a cartilha do CERT também apresenta recomendações relevantes. O **navegador, como qualquer outro software, deve estar sempre atualizado com a versão mais recente** e com todas as **correções de segurança aplicadas**. Isso inclui também os complementos e extensões instaladas, que muitas vezes representam pontos de vulnerabilidade.

O melhor é configurar o navegador para buscar e instalar atualizações automaticamente, evitando assim que o usuário se esqueça dessa tarefa essencial. Quando uma vulnerabilidade é identificada, os desenvolvedores rapidamente disponibilizam uma correção, e é por meio das atualizações automáticas que essa proteção chega ao usuário.

Outro aspecto a considerar é o uso de **linguagens como Java e JavaScript**, amplamente empregadas na construção de páginas web. Apesar de úteis e necessárias para o funcionamento de muitos recursos online, essas linguagens também podem ser exploradas por criminosos para executar scripts maliciosos automaticamente.

Para se proteger, é possível utilizar complementos como o **NoScript**, que permite liberar gradualmente a execução de scripts apenas em sites confiáveis. Com esse controle, o usuário evita que códigos sejam executados automaticamente sem seu consentimento, o que contribui significativamente para a segurança da navegação.

Portanto, adotar uma postura vigilante e preventiva, tanto nas operações bancárias quanto no uso de navegadores, é essencial para manter a integridade dos dados e evitar incidentes de segurança. Esses cuidados, embora simples, fazem toda a diferença na proteção das informações pessoais e financeiras no ambiente digital.

Outro cuidado fundamental ao utilizar navegadores da internet é em relação à execução de **programas ActiveX**. Esses programas são utilizados para executar funcionalidades específicas em sites, principalmente em jogos online e aplicações mais complexas, e podem ser executados automaticamente sem que o usuário perceba.

Por isso, é imprescindível **permitir que ActiveX sejam executados apenas em sites confiáveis e conhecidos**. Qualquer execução automática representa um risco potencial, já que pode estar carregando scripts maliciosos. A recomendação é clara: somente autorizar quando houver total confiança na procedência do conteúdo.

Também é importante ter **cautela com o uso de cookies**, especialmente para quem deseja manter um nível mais elevado de privacidade. Os cookies, como mencionado anteriormente em contextos relacionados a ameaças, são arquivos pequenos armazenados pelo navegador que registram informações sobre a navegação do usuário, incluindo dados pessoais e hábitos de uso.

Embora sejam úteis para personalizar a experiência e facilitar acessos, esses dados podem ser acessados por terceiros caso o computador não esteja devidamente protegido, comprometendo a privacidade do usuário.

Outro recurso que requer atenção é a funcionalidade dos navegadores que permite o armazenamento de senhas. Caso o usuário opte por utilizar esse recurso, é fundamental **cadastrar uma chave mestra**. Essa chave atua como uma senha principal que protege todas as demais senhas armazenadas no navegador.

Assim, sempre que o navegador precisar preencher automaticamente uma senha salva, ele só o fará após a inserção da chave mestra. Isso garante que, mesmo que outra pessoa utilize o computador, não conseguirá acessar serviços com as senhas do titular sem conhecer essa chave. Essa medida é indispensável quando se compartilha o uso de

dispositivos ou em ambientes onde há múltiplos usuários.

Por fim, **manter o computador seguro** é um princípio básico e contínuo. Apesar de não existir uma segurança absoluta, é possível atingir níveis elevados de proteção ao adotar práticas consistentes e atualizadas.

Isso inclui o uso de **antivírus confiáveis, firewall ativo, atualizações constantes de sistemas operacionais e programas, atenção ao que é instalado e aos sites acessados, além de cuidados com e-mails e links suspeitos.**

Tudo isso faz parte de uma postura de segurança da informação que, embora não elimine todos os riscos, reduz drasticamente as chances de incidentes e mantém a integridade dos dados e sistemas utilizados pelo usuário.

## 8. Protocolos de Segurança de Redes Sem Fio (Wi-Fi)

As redes sem fio se tornaram parte essencial do cotidiano, estando presentes em praticamente todos os ambientes, sejam profissionais ou domésticos.

No entanto, o uso dessas redes exige atenção especial aos protocolos de segurança que garantem a proteção dos dados transmitidos. Ao conectar-se a uma rede Wi-Fi, é fundamental compreender os mecanismos que estão por trás da proteção dessa comunicação.

Um dos primeiros protocolos utilizados para segurança em redes sem fio foi o **WEP**, sigla para Wired Equivalent Privacy. Esse protocolo buscava oferecer nas redes sem fio um nível de segurança equivalente ao das redes cabeadas. No entanto, com o passar do tempo, demonstrou-se que o WEP possui falhas graves de segurança, tornando-o vulnerável e facilmente quebrável.

Em resposta a essas limitações, surgiu o **WPA**, ou Wi-Fi Protected Access, como uma tentativa de corrigir as deficiências do WEP. Embora tenha representado um avanço, o WPA ainda não oferece um nível de segurança suficientemente confiável nos dias atuais.

Diante da necessidade de maior robustez, foi desenvolvido o **WPA2**, que representa uma evolução significativa. Esse protocolo utiliza o **algoritmo de criptografia AES** (Advanced Encryption Standard), reconhecido por sua alta eficiência e segurança.

O uso do WPA2 tornou as redes Wi-Fi muito mais protegidas, sendo atualmente o padrão recomendado para ambientes que buscam segurança adequada nas transmissões sem fio.

## 9. Controles

Além dos protocolos de rede, é importante entender os conceitos de **segurança física e segurança lógica**, pois ambos compõem as bases dos **controles de acesso** em ambientes de tecnologia da informação. A segurança física está relacionada à proteção do espaço físico onde estão os equipamentos e materiais.

Isso inclui o uso de **câmeras de vigilância, sensores térmicos, alarmes de movimento, guardas de segurança e mecanismos de biometria**. Esses recursos visam impedir que pessoas não autorizadas tenham acesso direto ao hardware, evitando, por exemplo, que equipamentos sejam danificados ou que informações sejam acessadas fisicamente.

Já a **segurança lógica diz respeito à proteção dos dados e sistemas digitais**. Ela controla o acesso a programas, arquivos, senhas, registros de atividades (logs) e demais componentes digitais.

Para garantir esse tipo de segurança, são utilizados recursos de hardware e software como a criptografia, que codifica os dados de forma a torná-los ilegíveis para terceiros; a assinatura digital, que assegura a autenticidade das informações; e também ferramentas como antivírus, firewalls e outros mecanismos destinados a prevenir ações maliciosas, como as realizadas por hackers ou crackers.

Compreender e aplicar esses conceitos de segurança é essencial para garantir a integridade, a confidencialidade e a disponibilidade das informações.

Ao longo desse conteúdo, foram abordados diversos pontos críticos sobre os procedimentos de segurança da informação, todos relevantes e frequentemente cobrados em provas e concursos. É recomendável revisar as questões sobre o tema para consolidar os conhecimentos adquiridos e estar melhor preparado para reconhecê-los e aplicá-los em contextos práticos e avaliativos.

---

## **Resumo**

### **1. Política de Segurança da Informação**

- Conjunto de diretrizes, normas e procedimentos para conscientizar e orientar os envolvidos na organização.
- Abrange servidores, diretores, funcionários, estagiários, fornecedores, parceiros e clientes.
- O ser humano é considerado o elo mais fraco da segurança da informação.
- Treinamento, educação e conscientização são fundamentais para garantir níveis elevados de segurança.

### **2, Tríade CID (Confidencialidade, Integridade e Disponibilidade)**

- Confidencialidade: apenas usuários autorizados acessam os dados.
- Integridade: garantia de que a informação permanece inalterada.
- Disponibilidade: informação acessível sempre que necessária.
- Ameaças e Vulnerabilidades:
  - Ameaça: potencial causador de dano (ataques, falhas, desastres).
  - Vulnerabilidade: fragilidade que pode ser explorada por uma ameaça.

### **3. Classificação da Informação**

- Critérios de Classificação:
  - Sensibilidade: impacto do vazamento da informação.
  - Criticidade: impacto da indisponibilidade ou perda da informação.
- Níveis Comuns de Classificação:
  - Pública: acesso irrestrito (ex: manuais institucionais).
  - Interna: uso exclusivo da organização (ex: atas de reunião).
  - Confidencial: acesso restrito, vazamento causa prejuízos (ex: dados de clientes).
  - Restrita: altamente sensível e crítica (ex: senhas e segredos industriais).
- Tratamento da Informação:
  - Definição clara de quem pode acessar, como armazenar e como descartar.
  - Aplicação de criptografia, controle de permissões e descarte seguro.

### **4. Conceitos Fundamentais**

- Senha: Conjunto de caracteres vinculado a um login (identificação do usuário).
- Autenticação: Processo de verificação da identidade do usuário.
- Autenticação em duas etapas (ou dois fatores): Combinação de senha e outro método (ex: token físico ou aplicativo).

### **5. Mecanismos de Autenticação**

- Biometria: Impressão digital, íris, retina, voz etc.
- Identificação por posse: Cartão, token de segurança.
- Identificação por conhecimento: Senhas, perguntas de segurança.

### **6. Formas de Descoberta de Senhas**

- Spywares e keyloggers em computadores infectados.
- Captura por webcam ou observação física da digitação.
- Sites falsos (phishing).
- Tentativas de adivinhação usando dados pessoais comuns.
- Intercepção em redes sem criptografia.
- Engenharia social.
- Acesso a arquivos de senhas não criptografados.

## **7. Boas Práticas no Uso de Senhas**

- Evitar ser observado ao digitar senhas.
- Nunca compartilhar senhas com terceiros.
- Sempre encerrar sessões (logout) após o uso.
- Criar senhas diferentes para cada serviço.
- Alterar senhas ao suspeitar de vazamentos.
- Evitar perguntas de segurança óbvias.
- Usar criptografia sempre que possível.
- Reduzir a exposição de informações pessoais nas redes sociais.
- Manter computador protegido com antivírus e firewall atualizados.

## **8. Elaboração de Senhas Fortes**

- Evitar:
  - Dados pessoais (nome, CPF, placa, datas).
  - Sequências de teclado (ex: QWERT, 123456).
  - Palavras comuns ou conhecidas (músicas, times, personagens).
- Recomendado:
  - Uso de números aleatórios.
  - Senhas longas.
  - Mistura de maiúsculas, minúsculas, números e caracteres especiais.

## **9. Conceito de Log**

- Arquivo que registra todas as ações de um usuário em um sistema.
- Útil para auditorias e diagnóstico de problemas.
- Mostra horários, acessos, comandos executados etc.

## **10. Segurança em Operações Bancárias (recomendações CERT)**

- Verificar se o site do banco usa HTTPS.
- Digitar a URL do banco manualmente; evitar links.
- Não usar mecanismos de busca para acessar bancos.
- Fornecer apenas uma posição do cartão de segurança por vez.
- Nunca passar dados por telefone ou e-mail.
- Desconsiderar mensagens de bancos desconhecidos.
- Em caso de dúvida, procurar diretamente o banco ou gerente.
- Não usar redes públicas ou computadores de terceiros para operações.

- Verificar extratos regularmente e agir rápido em caso de suspeitas.
- Confirmar a procedência de módulos de segurança antes de instalá-los.

### **11. Segurança no Uso de Navegadores**

- Manter navegador e extensões sempre atualizados.
- Configurar atualizações automáticas.
- Permitir Java e JavaScript apenas com controle (ex: NoScript).
- Permitir ActiveX apenas de sites confiáveis.
- Ter cuidado com cookies (privacidade).
- Caso armazene senhas no navegador, usar chave mestra.
- Manter o computador seguro com programas de proteção atualizados.

### **12. Protocolos de Segurança em Redes Sem Fio**

- WEP: Antigo e frágil.
- WPA: Evolução do WEP, mas ainda pouco seguro.
- WPA2: Atual, utiliza AES e oferece segurança confiável.

### **13. Segurança Física e Lógica**

- Segurança Física:
  - Controle de acesso ao ambiente físico (câmeras, alarmes, guardas, biometria).
- Segurança Lógica:
  - Controle de acesso aos sistemas e dados (senhas, logs, criptografia, assinatura digital, antivírus, firewall).

---

Texto: Professor(a) Ramon Ahnert Azeredo

**Proibida a reprodução e comercialização sem autorização**

Usuário: Julio Cesar Justini dornellas, julio.justini@gmail.com, CPF: 05536778960

---